SecureScan AI: Technical Architecture & Security Specification

Author: Vinod Kumar • **Version:** 2.4 Enterprise • **Status:** Production Ready

1. Executive Summary & Purpose

SecureScan AI is an automated, ethical web vulnerability scanning platform engineered in Python and modern web technologies. Unlike conventional indiscriminate scanners, SecureScan AI mandates formal ownership verification or educational sandbox pre-approval before any network packet is dispatched. This ensures full compliance with the Computer Fraud and Abuse Act (CFAA), ISO/IEC 27001, and OWASP testing frameworks.

2. Core Module Architecture

The platform is structured into four primary autonomous subsystems:

1. Target Scope Manager: Maintains target database records, generates cryptographically random ownership tokens, checks DNS TXT records, and strictly enforces RFC-compliant hostname matching.

2. Threat Neutralization & SSRF Defense: Pre-resolves target URLs and verifies that IP destinations do not match private subnets (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16), link-local addresses (169.254.0.0/16), or cloud metadata endpoints unless explicitly registered as an educational lab.

3. 7-Tier Vulnerability Scanner: Multi-threaded crawler with non-destructive heuristics testing SSL/TLS configuration, missing security headers (CSP, HSTS, X-Frame-Options), cookie flags (Secure, HttpOnly, SameSite), open redirect vectors, path traversal exposures, reflected XSS, and SQL error injections.

4. AI Explanation & Reporting Engine: Formulates real-time remediation playbooks using OpenAI GPT models with fallback deterministic security heuristics, outputting actionable CVSS scores and OWASP Top 10 mappings.

3. Complete REST API Specification

SecureScan AI exposes a high-performance RESTful API powering the responsive UI:

Method	Endpoint	Function & Scope
GET	/api/targets	Retrieve list of all authorized and registered target domains
POST	/api/targets	Register a new target with ownership verification method
POST	/api/verify/<id>	Trigger active verification probe (DNS TXT, HTML Meta)
POST	/api/scan	Launch authorized security scan with strict scope validation
GET	/api/scan/<id>/telemetry	Real-time telemetry, log stream, and module progression
GET	/api/scan/<id>/report/pdf	Generate and download comprehensive executive PDF report
GET	/api/compliance/audit	Query immutable audit logs for regulatory compliance

4. Database Schema Overview

The system utilizes an ACID-compliant SQLite relational database with WAL (Write-Ahead Logging) enabled. Key tables include targets, authorizations, scans, findings, scan_logs, and audit_logs. Foreign key constraints ensure cascading cleanup and transactional data integrity across multi-threaded operations.